

TokTickIT — Lab 3 Work Log

Issue #35 · Authentication Foundation · branch feature/2-authentication-foundation

1. Overview

Feature 2 builds the authentication foundation every remaining Lab 3 branch depends on: real User accounts (replacing Lab 2's Requester dev-selector), password hashing, sessions, and the login / logout / current-user / change-password API and screens. Written ahead of Feature 1's PR review landing, so review turnaround on #43 doesn't block progress.

Field	Value
Branch	feature/2-authentication-foundation
Base branch	lab3-staging
Issue	#35 — Authentication Foundation
PR	#44 -> lab3-staging (open, awaiting review)
Commit	7c0945a — feat: authentication foundation (User/Session model, login, forced password change)
Files changed	21 files (1,399 insertions, 59 deletions)

2. What Was Added, by Category

2.1 Data model & migration

New Prisma models User (Role enum: REQUESTER / IT_STAFF / ADMINISTRATOR) and Session.

Ticket.requesterId retargeted from the old Requester table to User. Migration

20260919060000_lab3_auth_foundation follows the expand -> backfill -> contract plan from specification.md §7.4: every existing Requester row became a User row with the identical id, so no Ticket row needed rewriting.

Check	Result
User count after migration	5 (matches the 5 pre-migration Requester rows)
Ticket/Attachment/Category/RelatedSystem counts	Unchanged (15 / 5 / 5 / 8)
Every Ticket.requesterId resolves to a User	Yes, checked directly against the live DB
Requester table	Dropped (contract step) — confirmed absent from the generated Prisma client

2.2 Backend — auth API (server/src/auth.ts, server/src/app.ts)

- bcrypt (cost 12) password hashing + verification (auth.ts).
- Server-side Session table backing an HttpOnly / SameSite=Lax toktickit_session cookie, 8-hour fixed expiry.
- POST /api/auth/login, POST /api/auth/logout, GET /api/auth/me, POST /api/auth/change-password.
- requireAuth middleware (used by the 4 routes above) and two more exported for Feature 3 to apply elsewhere: requirePasswordUpToDate and requireSameOrigin.
- GET /api/tickets, POST /api/tickets, GET /api/requesters: internally repointed from the old Requester model to User (role=REQUESTER) with zero change to their request/response shape.

Deliberately not done here: Lab 2's ticket/attachment routes are not yet session-gated — they still take a requesterId parameter exactly as in Lab 2. Wiring requireAuth (and role/ownership checks) onto them, and removing the client's dev-requester picker, is Feature 3's job (Authorization & Requester Regression) so this

TokTickIT — Lab 3 Work Log

Issue #35 · Authentication Foundation · branch feature/2-authentication-foundation

branch stays a clean, independently reviewable foundation.

2.3 Frontend — screens (client/src/Login.tsx, ChangePassword.tsx)

Two new standalone screens per ui-spec.md §2 and §4, plus 4 new functions in api.ts (login, logout, getCurrentUser, changePassword). Not yet wired into App.tsx's navigation flow — that integration (app shell, role-based nav) is Feature 3's job.

Screen	States covered
Login	idle, loading, field validation, safe 401 message, network/500 error, success
Change Password	idle, loading, field validation (from API), wrong-current-password (401), success

2.4 Seed data

server/prisma/seed.ts now seeds 10 Users: the 4 active + 1 inactive migrated Requesters, plus 3 active + 1 inactive IT Staff and 1 active Administrator (new), matching specification.md §7.5. All 10 share one documented local-dev default password (SEED_DEFAULT_PASSWORD in server/.env.example, never committed as a real secret) and mustChangePassword: true.

TokTickIT — Lab 3 Work Log

Issue #35 · Authentication Foundation · branch feature/2-authentication-foundation

3. Test Evidence (Actually Run on This Branch)

Suite	Result
Server — npm test	11 test files, 111/111 tests passing
■ Lab 1 + Lab 2 (unmodified behavior)	9 files, 93/93 passing
■ Lab 3 migration invariants (new)	1 file, 4/4 passing
■ Lab 3 auth API + password helpers (new)	1 file, 14/14 passing
Client — npm test	7 test files, 51/51 tests passing
■ Lab 1 + Lab 2 (unmodified behavior)	5 files, 42/42 passing
■ Lab 3 Login + ChangePassword (new)	2 files, 9/9 passing
Server build (tsc / npm run build)	Clean, no errors
Client type-check (tsc --noEmit)	Clean, no errors

Regression note: Lab 2's test files needed one mechanical change each — their own setup/teardown fixtures called `prisma.requester.*` directly (not through the API) to seed test data, and that model no longer exists after the migration. Every occurrence was renamed to `prisma.user.*` with a role: "REQUESTER" filter added so the fixtures keep matching only Requester-role accounts, not the new IT Staff/Administrator rows. No assertion, expected value, or tested behavior changed — this is a rename, not a behavior edit.

4. Traceability to tests.md

tests.md ID	Status after this branch
UNIT-01, UNIT-02	Pass
API-01 through API-09, API-11	Pass
API-10 (forced-password-change gate on other routes)	Deferred — no other protected route exists yet; <code>requirePasswordUpToDate</code> is built and exported for Feature 3
MIG-01 through MIG-04	Pass
UI-01, UI-02 (Login)	Pass
UI-03 (Change Password)	Pass
REG-01 (Lab 1+2 regression)	Pass (111+51 above)

5. Next Step

PR #44 is open against lab3-staging, awaiting review alongside #43 (Feature 1). Feature 3 (Authorization & Requester Regression, issue #36) is unblocked as soon as this merges: it wires `requireAuth` / `requirePasswordUpToDate` / `requireSameOrigin` onto Lab 2's ticket and attachment routes, removes the client's dev-requester picker, adds role-based app-shell navigation, and adds Public Comments + "Problem Appears Resolved" to the Requester Ticket Detail screen.